Build the Intent Firewall, Not Illia's List

Furqaan should build **Intent Firewall**, rebuilt as a hybrid. An agent's NEAR smart-wallet contract runs an action only when it carries a TEE-signed "ALLOW" verdict from NEAR AI Cloud. The verdict covers the exact action bytes, and the contract checks it on-chain with `sha256` + `ecrecover`. Enter it in **AI Security & Defense**, **Agent Economy** and **Privacy & Private AI**. It scores 4.25/5 on the weighted rubric below, against 3.45 for the runner-up. It wins because it is the only candidate that is buildable with documented APIs, absent from Illia's Oct 3 list of 13 ideas, and a word-for-word match for a track's hints. The Security track asks for "AGENT SECURITY, FUNCTION CALL KEYS, TEE ATTESTATION" (nearhackathon.com). It also lands with the judges most likely to mark down the other ideas. Haseeb Qureshi says AI's real uses "remain within software engineering and security" (haseebq.com), and Avichal Garg calls agent-wallet liability an unsolved frontier (CoinDesk). The runner-up is **Sealed-lite**, a scoped-down Sealed: a public NEAR escrow with commit-reveal sides, 1Click cross-chain funding and an attested AI resolver. It fits Furqaan's prediction-market background best. But Confidential Intents cannot hold contract balances, so most of its "confidential" claim falls away, and Haseeb is openly skeptical of new prediction markets. Six of the ten ideas copy Illia's list almost word for word, so expect crowded tracks. Copy-Key is not buildable as specified, and Intents Ledger is already lapped by a public repo. Both top picks rest on one unproven step: verifying a real NEAR AI signature inside a NEAR contract. Run that test on Day 1, before writing anything else.

Six of ten ideas copy a head judge's public wishlist

The hackathon pays $10K/$3K/$2K across **13 tracks** plus one **$55K grand prize**, all paid in NEAR. One submission can name every track it fits, but it cannot be edited after it is sent (nearhackathon.com; HACKATHON.md). Illia Polosukhin is the anchor judge. On Oct 3 he posted 13 app ideas, and **Whisper OTC, Copy-Key, Never-Liq, Stake-to-Show, Factmarket and Pocket Pet each map almost word for word** onto one of them (crypto.news). The list is public and posted four weeks before kickoff by a judge, so it works as a de facto idea sheet. Any idea on it starts on-thesis with Illia and weak on originality, which is one of the five stated criteria. The others are technical implementation, design, impact and sustainability (nearhackathon.com). Large online NEAR events are harsh: One Trillion Agents had 2,000+ participants and named only 40 top submissions (Bitte). A solo builder wins by being the clearly best entry in a less-crowded lane, not the fifth-best AI pet.

The table scores each idea at the scope it can actually be built today, on six 1–5 dimensions. The weights are my judgment: feasibility 25%, originality/duplicate risk 20%, judge-panel fit 20%, NEAR primitive depth and track-hint fit 15%, demo legibility for human and AI judges 10%, founder fit 10%. The winner holds up under other weights too. With equal weights Intent Firewall scores 4.33 and Sealed-lite 3.67. Only a rubric that weights judge fit far above everything else lifts Whisper OTC or Never-Liq, and both of those fail on feasibility.

Rank	Idea (as buildable)	Feas.	Orig.	Judges	NEAR depth	Demo	Founder	Weighted	Call
1	**Intent Firewall** (own wallet contract + NEAR AI signed verdicts)	4	4	4	5	5	4	**4.25**	**Build**
2	**Sealed-lite** (commit-reveal escrow + 1Click + attested resolver)	3	3	3	4	4	5	**3.45**	Reserve
3	Bidwire	5	2	3	3	4	3	3.40	Pass
4	Whisper OTC	2	2	5	5	3	3	3.25	Pass
5	Never-Liq	2	2	5	4	2	3	3.00	Pass (Rhea risk)
6	Stake-to-Show	5	1	2	3	4	3	3.00	Pass

Rank	Idea (as buildable)	Feas.	Orig.	Judges	NEAR depth	Demo	Founder	Weighted	Call
7	Factmarket	4	2	2	2	3	5	2.90	Pass
8	Intents Ledger (thesis)	4	1	3	2	3	2	2.60	Pass
9	Pocket Pet	3	1	2	3	4	3	2.50	Pass
10	Copy-Key	1	2	4	3	2	4	2.50	Not buildable

Confidential Intents cannot hold contract balances, which guts three ideas

The biggest technical finding is that **Confidential Intents is a swap/transfer/balance product exposed only through 1Click**. It runs on "FAR", a permissioned NEAR fork with no public RPC, and the only documented contract there is the predefined `intents.far` (NEAR Intents MM docs). Aurora's docs say it plainly: "Confidential Intents is not private DeFi and does not obscure the destination." Confidential deposits and DeFi actions are still "rolling out" (Aurora Intents docs). A live test on Oct 22 found that confidential quotes return **401 without a per-user signed session** (1Click API). Since Jul 13, confidential solvers have been allowlist-only (changelog). On the documented APIs, then, no hackathon contract can hold shielded balances. Third-party apps cannot consume view keys; the only evidence for view keys is the GA blog's "user-initiated" line (NEAR blog). And no app can act as a confidential matcher.

Three more facts shape the field. **Shade Agents have been unmaintained since Apr 19, 2026** (docs.near.org), so the TEE route runs through NEAR AI Cloud or OutLayer. Rhea lending was hit by an **$18.4M exploit on Apr 16**, and its reopening is unconfirmed (The Block). And after the $3.8M ghost-balance exploit, **`intents.near`'s deposit `Notify` was removed entirely on Oct 7**, so any design that relied on a deposit triggering contract logic now needs an off-chain relayer (ChainCatcher; The Coding postmortem). On the positive side, 1Click is mature. It lists 205 assets on 37 chains, quotes return in about 1 s, and a Base→Arbitrum USDC route estimates 34 s (1Click tokens). NEAR AI Cloud signs every response with EIP-191 ECDSA or Ed25519 over `sha256(request):sha256(response)`, a format a NEAR contract can check (NEAR AI docs).

Idea	Best evidence for	Decisive risk
Intent Firewall	GREEN as its own wallet contract. NEAR AI signatures are contract-verifiable (NEAR AI). The track hints match it exactly. Not on Illia's list.	OutLayer already does rule-based TEE policy (OutLayer). Rule-based WIP repos AgentSentinel and Guardia target the same track (agent-sentinel). VCs may see "infra with no users".
Sealed-lite	Founder fit is maximal. NearMarket, an AI prediction market on Intents, won a NEAR hacker house in Sept 2025 (Medium). UMA's whale-dominated disputes give a sharp pitch (track360).	Bet sizes stay public, so "confidential" shrinks to origin-wallet unlinkability. Haseeb: "90% of prediction market offerings are totally ignored" (haseebq.com). Arcium already hosts private PMs on Solana (Eli5DeFi). 10–12 dev-days is tight.
Bidwire	Every piece is documented and stable (7–9 days).	NEAR already runs bids, escrow and a dispute agent at market.near.ai. A sealed-bid TEE build exists from ETHOnline (GitHub). Haseeb doubts agents will pay each other in 2026.
Whisper OTC	Illia #9. Fits Mert's "market of markets" and Kain's Infinex Confidential (MPost).	Allowlisted solvers mean no guaranteed direct maker↔taker fill at a fixed price. near.com already ships P2P private deals. Dragonfly backs Renegade (The Block).
Never-Liq	Illia #11, and a perps/security angle that appeals to Kain and Haseeb.	Rhea lending status is unknown. DeFi Saver already protected $446M (Crypto Briefing). The demo needs a live at-risk position.
Stake-to-Show	The simplest GREEN build (5–7 days).	Illia #5 verbatim. Kickback and ShwUp already exist (ShwUp). The ceiling with the VC and DeFi judges is low.
Factmarket	No shipped market-backed wiki exists. Founder fit is high.	Illia #2 verbatim. NEAR primitive depth is thin. Haseeb is skeptical of prediction markets.
Intents Ledger	Rich public data.	**NEAR Books** is already an attested, re-runnable Intents audit with 185 tests that targets the same track (GitHub).

Idea	Best evidence for	Decisive risk
Pocket Pet	Illia listed it first.	No crypto or on-chain payment path for NEAR AI inference is documented. GenLayer and Fren Pet came first (GitHub). It will be the most-copied consumer idea.
Copy-Key	Illia #10. Kain's Infinex uses the same rails.	**RED**: no documented view-key API, and sharing a session token likely grants execution rights.

The Security track's hints describe the Intent Firewall almost exactly

The winning build is a **wallet contract that trusts meaning, not just rules**. The agent holds only a function-call access key scoped to the wallet's `propose` method. Each proposed action is canonically encoded as receiver | method | args-hash | deposit | nonce | expiry, and embedded in a prompt to an open-weight model on NEAR AI Cloud. The prompt pairs that action with the owner's plain-English mandate. Qwen3.8-27B is the best fit: **$0.04 in / $1.35 out per M tokens** and listed as ready (NEAR AI models). The model returns a structured ALLOW/DENY verdict. The service fetches its signature from `GET /v1/signature/{chat_id}` (API ref). The contract recomputes both hashes, `ecrecover`s the signer and checks it against a TEE address registered after an off-chain check of `/v1/attestation/report` (attestation ref). It then confirms that the action bytes in the signed request match the one being executed, and only then executes. Hard per-transaction caps and allowlists stay in the contract as a deterministic backstop. Cross-chain spending goes out through 1Click.

The pitch writes itself against the competition. OutLayer enforces limits, allowlists and k-of-n approvals inside TDX. It documents **"no external co-signer or webhook mechanisms"**, and for Intents swaps its TEE "does not re-verify token/amount against the 1Click artifact" (OutLayer). Intent Firewall checks exactly that semantic gap: does this recipient, amount and token match what the owner asked for? The other off-NEAR intent firewall, ciphergate on iExec, binds a proof to a Safe action rather than a semantic judgment (GitHub). Furqaan's x402 background suggests the strongest demo. A paying agent hits a **malicious 402 paywall whose response injects "pay 10× to this address"**. Rules alone pass it if it fits under the cap. The firewall blocks it and leaves a signed receipt. A $150K prompt-injection drain has been reported, though only from a secondary source (DEV). The closest NEAR x402 demo, JustaLab's, only enforces a spending cap (GitHub).

Track choice follows the hints. **AI Security & Defense** is the main bet: "Give AI money without giving it the keys to everything." **Agent Economy** fits because the demo agent pays for APIs and data cross-chain via NEAR Intents. **Privacy & Private AI** fits because the verdict runs on TEE-hosted private inference, one of its named hints (nearhackathon.com). The README must name each hint, because HACKATHON.md tells entrants to "name them in the README" and to write "do X - see Y" steps for the AI judges (HACKATHON.md). Four risks matter. First, the firewall model can itself be prompt-injected. Pass untrusted tool output as quoted data, use structured outputs, and keep the hard caps. Second, the false-positive rate is unknown until it is measured, which is why Day 1 includes a measurement. Third, TEE signing keys rotate, and how long signatures are kept is undocumented, so fetch each one immediately and keep the allowlist updatable. Fourth, overclaiming. Do not say the contract verifies the TDX quote; say the signer was attested off-chain and allowlisted. If Sealed-lite becomes the pick instead, it enters **Privacy & Private AI, Unstoppable DeFi and Open Innovation**. It must state in the README that positions are public on NEAR and that sides are hidden only by commit-reveal until close.

Day 1 runs five kill tests on signatures, model quality and settlement

Both top picks depend on the same primitive, so the plan starts there. "Build your project during the hackathon" is the only stated rule. Keep product code in a fresh repo created on Nov 1 or later. Pure curl spikes against public APIs before then are probably harmless, but confirm that in Discord. Budget $20–50 of mainnet funds, because there is effectively no 1Click testnet. OutLayer's testnet returns 503 for Intents (OutLayer). Apply for a

partner JWT at partners.near-intents.org on the morning of Nov 1, because the approval time is undocumented and unauthenticated quotes pay an extra 0.25% (1Click auth). Check every field name against `https://1click.chaindefuser.com/docs/v0/openapi.yaml` and the NEAR AI API reference before coding. HACKATHON.md explicitly warns against assuming endpoints.

Test	Exact calls / checks	Pass	Fail → action
KT1: get a signed verdict (both picks), hours 0–3	`GET https://cloud-api.near.ai/v1/models` and confirm Qwen/Qwen3.8-27B is ready. `POST /v1/chat/completions` (non-streaming, JSON structured output `{verdict, reason}`), saving the **raw request and response bytes** before parsing. `GET /v1/signature/{id}?model=Qwen/Qwen3.8-27B&signing_algo=ecdsa`. `GET /v1/attestation/report?model=…&signing_algo=ecdsa&nonce=<fresh 32-byte hex>`. Locally, `ethers.verifyMessage(sha256hex(req)+":"+sha256hex(resp), sig)`.	The recovered address equals the signing address from both the signature endpoint and the attestation report, and the report echoes your nonce.	The local hash does not reproduce: try `signing_algo=ed25519` with `nacl.sign.detached.verify`, and check whether the gateway hashes canonicalized JSON. Still failing at hour 6: ask NEAR AI in Discord and plan the trusted-relayer fallback.
KT2: on-chain verification (both picks), hours 3–8	A minimal near-sdk-rs contract on testnet. `verify(req: Vec<u8>, resp: Vec<u8>, sig: [u8;65])` computes `env::sha256` of each and hex-encodes them, builds the EIP-191 prefixed message, applies `env::keccak256`, calls `env::ecrecover(hash, sig[..64], v=sig[64]-27, …)`, derives the address as `keccak256(pubkey)[12..]`, and compares it to an allowlisted signer. Call it with the KT1 artifacts.	Returns `true` for the genuine pair and `false` when one byte of `resp` is flipped. Record the gas use, which must leave headroom inside one call, and repeat with a 4 KB response.	Gas or argument size is too large: pass `resp` in full but cap the response length, or verify Ed25519 with `env::ed25519_verify`. Both fail: off-chain verifier relayer with its own allowlisted key, with the trust assumption stated honestly.
KT3: semantic quality (Firewall only), hours 8–11	20 malicious scenarios (injected recipient swap, amount 10× the mandate, unknown-token swap, approval to an unknown contract, poisoned 402 paywall) and 20 benign ones, all run through the KT1 prompt on Qwen3.8-27B. Repeat with GLM-5.3-flash.	≥18/20 malicious denied, ≤2/20 benign denied, median latency <5 s. These thresholds are my bar.	Below the bar on both models: tighten the canonical action schema and mandate format, retest on Day 2, and if it still fails, **switch to Sealed-lite**.
KT4: settlement path, hours 11–14	`GET /v0/tokens` for asset IDs. `POST /v0/quote` with `dry:true`, origin NEAR USDC → Base USDC, amount ≈ $2, `refundTo`/`refundType` set to the wallet, `recipientType: DESTINATION_CHAIN`. Then a real quote, an `ft_transfer` from a test wallet account to the `depositAddress`, `POST /v0/deposit/submit`, and polling `GET /v0/status`. Separately, add a function-call key on the wallet and try to call another contract with it.	Funds arrive on Base in roughly a minute, and the status reaches its terminal success state. The out-of-scope call is rejected by the protocol.	A per-route minimum blocks it (a 0.10 USDC quote was rejected on Oct 22) or the route fails: raise the amount or switch routes. Quotes failing entirely: escalate in Discord before Day 2.
KT5: Sealed-lite only (run only if KT3 fails)	Authenticate a user through the "Authenticate User with Signed Data" endpoint (llms.txt), then `POST /v0/quote` with `confidentiality:"basic"` and `recipientType:"CONFIDENTIAL_INTENTS"` using the user's access token. Separately, 1Click-deliver USDC to the market contract's NEAR account and confirm that a relayer can credit the bettor from `/v0/status` without `Notify`.	A non-401 confidential quote with a deposit address. The relayer credits the bettor within one minute of a success status.	Still 401 with a valid token: drop the confidential leg and the "Sealed" name, and build a public attested-resolver market. Delivery fails: bettors `ft_transfer_call` the contract directly.

Decision rule: if KT1, KT2 and KT3 pass by the end of Nov 1, commit to Intent Firewall and stop evaluating. If KT2 fails, both picks lose on-chain verification by the same amount, so the Firewall still leads with a relayer fallback. If KT3 fails twice, Sealed-lite takes over.

Questions to settle in NEAR Discord before Nov 1

Ask these in the NEAR AI, NEAR Intents and OutLayer channels, and the organizer questions in the hackathon channel (discord.gg/nearprotocol). The rules leave real gaps. There is no rubric weighting, no statement on whether one project can win several track prizes, no mainnet requirement, no prior-code policy and no KYC terms (HACKATHON.md).

#	Question	Who	What it decides
1	Do proprietary models (Claude, GPT) on NEAR AI Cloud return TEE signatures, or only NEAR-hosted open models? How long are `/v1/signature/{id}` results retained, and how often do signing addresses rotate?	NEAR AI	Model choice, the allowlist design and the "fetch immediately" rule.
2	Are there hackathon credits for NEAR AI Cloud? Can usage be paid in crypto or on-chain?	NEAR AI	Cost (trivial either way). Also sets Pocket Pet's feasibility, for the record.
3	Is there an API (not the dashboard) for submitting OutLayer multisig approvals, so a bot can be a Signer? Is a co-signer or webhook policy hook planned? Can `request_execution` WASM make outbound HTTPS calls?	OutLayer	Whether to ship an "OutLayer + Firewall" integration alongside the own-contract wallet.
4	After the Oct 7 `Notify` removal, does `ft_withdraw`/`mt_withdraw` with `msg` still trigger `ft_on_transfer` on a NEAR contract? Can 1Click deliver to a contract with a custom msg?	NEAR Intents	Whether funds can land in the wallet or market contract atomically or must go through a relayer.
5	How long does partner JWT approval take? Are there hackathon fee waivers? Is the Sep 9 temporary $1,000 origin→origin minimum still active, and on which chains? What does the `insured` quote field mean?	NEAR Intents	Mainnet testing cost and route selection.
6	What separates `confidentiality: "basic"` from `"advanced"`? Can a contract account be a confidential recipient? Is there a view-key API?	NEAR Intents	Sealed-lite's privacy claim. Also confirms Copy-Key stays RED.
7	Is Rhea lending live on mainnet, with the same contract and methods?	Rhea	Confirms the Never-Liq pass.
8	Is there an official successor to Shade Agents that judges expect?	NEAR	Avoid looking dated on the TEE stack.
9	Can one project win prizes in more than one track, and can the grand-prize winner keep a track prize?	Organizers	How many tracks are worth tuning the README for.
10	Is throwaway spike code from before Nov 1 acceptable if the submitted repo starts on Nov 1? Do the AI judges execute code, and is mainnet deployment weighted?	Organizers	Day-1 timing and how much polish to spend on the mainnet deploy.
11	Is KYC or a sanctions check required before NEAR payouts, and what is the NEAR/USD conversion rule?	Organizers	Payout readiness for an India-based winner.

A 14-day build that ships one complete workflow

Organizers ask for "something that works", and the AI judges will follow the README literally. So the plan protects one end-to-end flow over breadth: agent proposes, firewall judges, contract verifies, funds move cross-chain, receipt is shown (nearhackathon.com). The deadline is **Nov 14 23:59 UTC, which is 05:29 IST on Nov 15**. Submit on the evening of Nov 14 IST, after the repo is public and the X post is live, because a second submission is rejected (HACKATHON.md).

Day	Deliverable
1 (Nov 1)	KT1–KT4. Partner JWT and NEAR AI key requested. Fresh repo.
2	Wallet contract skeleton in near-sdk-rs: `propose`, `execute`, signer registry, nonce/expiry replay guard, hard caps. Agent function-call key.
3–4	Verdict binding: canonical action encoding, signed-request check that the embedded action matches the executed one, JSON verdict parsing. Unit and sandbox tests. Off-chain attestation checker that registers signers.
5	Firewall service in TypeScript: mandate + action → NEAR AI structured verdict → signature fetch → contract submit. Raw bytes persisted.

Day	Deliverable
6	Demo agent with a scoped key that buys data from an x402-style paywall and pays cross-chain.
7	1Click execution from the wallet: NEAR USDC → Base, status polling, refund handling.
8	Red-team suite (`make redteam`) of 20+ malicious and 20+ benign cases, with block and false-positive rates published in the README.
9	Hardening: injection-resistant prompt layout, caps as backstop, signer rotation, a freeze switch.
10	UI: proposal feed, verdict with reason, signature and attestation links, explorer tx links.
11	Mainnet deploy (with explicit confirmation), with real tx hashes for one allowed and one blocked action. OutLayer integration only if Discord Q3 comes back yes.
12	README for machine readers: problem, architecture diagram, threat model, honest trust assumptions, "do X - see Y" steps, each track hint named, one-command test run.
13	Feature freeze. Demo video under about 2:20: attack blocked, benign payment allowed, receipt verified. X post tagged NEAR HACKATHON.
14 (Nov 14)	Buffer. Final public-repo check. Submit through the form or `POST /api/applications` with the security, agents and privacy track ids.

Conclusion

The research turns the selection question upside down. The ideas most obviously "on thesis" are the riskiest. Illia's wishlist will crowd them, and the most glamorous of them (true Sealed, Copy-Key, private-fill OTC) need confidential contract state that NEAR does not expose. What NEAR does expose, and what few entrants will use well, is **verifiable AI output that a contract can check**. That is a NEAR-native answer to the agent-liability problem the investor judges keep raising. Intent Firewall turns that into a product whose demo is a visible attack being stopped, which both the human and AI judges can verify from the README alone.

The bigger implication is that the attested-verdict verifier is reusable. The same contract that gates an agent's spending can resolve a Sealed-lite market or arbitrate a Bidwire job. So the Day-1 work is never wasted, whichever way KT3 lands. It also gives Furqaan a post-hackathon path back to prediction markets, built on infrastructure he will already have shipped. The main unknown is how strong the field is. Track entry counts cannot be seen until judging. The only lever left is execution depth, so the scope should stay narrow.